UNIVERSIDAD PERUANA

CAYETANO HEREDIA



FACULTAD DE CIENCIAS E INGENIERÍA

"ALBERTO CAZORLA TALLERI"

Departamento Académico de Ciencias Exactas - Sección Ingeniería

INFORME 8

CURSO

SISTEMAS OPERATIVOS

INTEGRANTES

- Huancas Bereche, Erick Emilio
- Pellanne Aro, Carlos Alfredo
- Reyes Garcia Alvaro Pablo
- Rivera Garayar, Matias Gabriel
- Romero Quispitongo, Luis Antonio
- Chara Franco, Johan Daymar

DOCENTE

Dr. Roberto Eduardo Burga Montañez

GRUPO

SOIF1 - G2

ACTIVIDAD 1. ANÁLISIS DE AMENAZAS DE SEGURIDAD

1.1. Descripción del caso

Una empresa almacena información confidencial de sus clientes, como datos personales, información financiera, contraseñas y registros de transacciones. Estos datos se encuentran en bases de datos y sistemas informáticos que podrían ser afectados por amenazas internas o externas.

El objetivo es identificar los riesgos y establecer medidas de protección que garanticen la confidencialidad, integridad y disponibilidad de la información.

1.2. Matriz de riesgos

Amenaza	Activo afectado	Impacto	Objetivo comprometido
Malware o ransomware	Servidores y bases de datos	Alto: robo, cifrado o pérdida de información	Confidencialidad, integridad y disponibilidad
Phishing	Credenciales de empleados y clientes	Alto: robo de cuentas y accesos no autorizados	Confidencialidad e integridad
Acceso no autorizado	Sistema de información de clientes	Alto: consulta o extracción de datos privados	Confidencialidad
Modificación maliciosa de registros	Base de datos de clientes	Alto: alteración de datos personales o financieros	Integridad
Ataque de denegación de servicio (DoS)	Servidores y aplicaciones	Alto: interrupción de los servicios	Disponibilidad
Fallo de hardware	Servidores y dispositivos de almacenamiento	Medio o alto: interrupción o pérdida de datos	Disponibilidad e integridad

Error humano	Archivos y registros de clientes	Medio o alto: eliminación o divulgación accidental	Confidencialidad, integridad y disponibilidad

1.3. Medidas preventivas

- Instalar y mantener actualizado un antivirus o sistema de protección contra malware.
- Utilizar autenticación multifactor (MFA) y contraseñas robustas.
- Capacitar a los empleados para reconocer correos fraudulentos.
- Aplicar permisos de acceso según las funciones de cada trabajador.
- Realizar copias de seguridad periódicas y comprobar su recuperación.
- Mantener actualizados los sistemas operativos y las aplicaciones.
- Registrar y revisar los eventos de seguridad para detectar actividades sospechosas.

Conclusión: La empresa debe adoptar controles preventivos, detectivos y correctivos para reducir los riesgos y proteger los datos de sus clientes.

ACTIVIDAD 2. DETECCIÓN DE ACCESOS NO AUTORIZADOS

2.1. Clasificación de los ataques

Situación	Tipo de ataque
Un usuario prueba miles de contraseñas automáticamente	Ataque de fuerza bruta
Se recibe un correo falso solicitando credenciales	Phishing
Un programa captura las teclas pulsadas	Keylogger o registrador de teclas
Se interceptan datos durante una transmisión	Ataque de intermediario (Man-in-the-Middle o MITM)

2.2. Preguntas de reflexión

¿Cuál ataque considera más peligroso para una universidad?

El phishing es uno de los ataques más peligrosos para una universidad porque puede engañar a estudiantes, docentes y administrativos para que entreguen sus credenciales. Con una cuenta comprometida, un atacante podría acceder a información académica, datos personales, correos institucionales o plataformas virtuales. Su impacto aumenta cuando las cuentas no cuentan con autenticación multifactor.

¿Qué medidas de prevención propondría?

1. Capacitar a los usuarios para identificar correos sospechosos.
2. Implementar autenticación multifactor en las cuentas institucionales.
3. Utilizar filtros antispam y herramientas de detección de enlaces maliciosos.
4. Aplicar políticas de contraseñas seguras y evitar su reutilización.
5. Limitar los intentos de inicio de sesión y bloquear temporalmente los accesos sospechosos.
6. Mantener los equipos actualizados y utilizar protección antimalware.
7. Establecer un procedimiento para reportar incidentes de seguridad.

Conclusión: La prevención requiere combinar tecnología, capacitación y procedimientos de respuesta ante incidentes.

ACTIVIDAD 3. DISEÑO DE UNA POLÍTICA DE SEGURIDAD

Política de seguridad del laboratorio de informática universitario

1. Objetivo

Establecer las normas para el uso seguro de los equipos, las cuentas y los recursos digitales del laboratorio de informática, protegiendo la información institucional y garantizando la disponibilidad de los servicios.

2. Alcance

Esta política se aplica a estudiantes, docentes, personal administrativo y técnicos que utilicen los equipos, las redes y los sistemas informáticos del laboratorio.

3. Gestión de contraseñas

- Cada usuario debe utilizar una cuenta individual e intransferible.
- Las contraseñas deben ser largas, únicas y difíciles de adivinar; se recomienda una longitud mínima de 14 caracteres cuando el sistema lo permita.
- Está prohibido compartir contraseñas o anotarlas en lugares visibles.
- Se recomienda activar la autenticación multifactor en los servicios que la permitan.
- Si existe sospecha de exposición de una contraseña, el usuario deberá cambiarla y comunicar el incidente al responsable del laboratorio.
- Los administradores deben aplicar permisos mínimos y proteger las cuentas privilegiadas.

4. Uso de dispositivos USB

- Solo se deben conectar dispositivos USB autorizados y necesarios para las actividades académicas.

- Los dispositivos externos deben analizarse con herramientas de seguridad antes de abrir sus archivos.
- Está prohibido utilizar USB para instalar programas no autorizados o copiar información confidencial sin permiso.
- Si se detecta un dispositivo sospechoso, debe desconectarse de forma segura y comunicarse al responsable técnico.
- Se recomienda utilizar medios institucionales para transferir información sensible.

5. Acceso a internet

- El acceso a internet debe utilizarse con fines académicos, de investigación y administrativos autorizados.
- Está prohibido acceder a sitios fraudulentos, descargar software ilegal o ejecutar herramientas maliciosas.
- No se deben desactivar el antivirus, el cortafuegos ni otros controles de seguridad.
- Los usuarios deben respetar las normas de propiedad intelectual y protección de datos.
- La institución podrá registrar y supervisar el uso de la red con fines de seguridad, bajo criterios de proporcionalidad, transparencia y respeto a la privacidad.

6. Respaldo de información

- Los responsables técnicos deben establecer copias de seguridad periódicas de la información institucional importante.
- Las copias deben almacenarse en ubicaciones protegidas y con acceso restringido.
- Se recomienda conservar copias separadas del entorno principal, incluyendo copias fuera de línea o protegidas contra modificaciones.
- Se deben realizar pruebas periódicas de restauración para comprobar que los respaldos funcionan.
- Los usuarios deben guardar sus trabajos en los espacios institucionales habilitados y no depender exclusivamente del almacenamiento local de los equipos compartidos.

7. Sanciones por incumplimiento

El incumplimiento será evaluado según su gravedad, las normas universitarias y la legislación aplicable. Las medidas podrán incluir:

- Advertencia formal.
- Suspensión temporal del acceso al laboratorio o a determinados recursos.
- Comunicación a las autoridades académicas o administrativas.
- Procedimientos disciplinarios en casos graves o reiterados.
- Denuncia ante las autoridades competentes cuando corresponda legalmente.

Las medidas deberán respetar el debido procedimiento y permitir la evaluación de las circunstancias de cada caso.

8. Responsabilidades y revisión

Los usuarios deben cumplir esta política y reportar incidentes. El personal técnico debe mantener los controles de seguridad, atender los reportes y revisar periódicamente su eficacia. La política se actualizará cuando cambien los riesgos, los sistemas o las normas aplicables.

Conclusión: Una política clara ayuda a prevenir incidentes, promover el uso responsable de los recursos tecnológicos y proteger la información universitaria.

ACTIVIDAD 4. TALLER DE AUTENTICACIÓN Y VALIDACIÓN

Comparación de métodos de autenticación

Método	Nivel de seguridad	Ventajas	Desventajas
Contraseña tradicional	Bajo a medio, según su robustez y los controles adicionales	Económica, sencilla y ampliamente compatible	Puede ser robada, adivinada, reutilizada o compartida
Doble factor de autenticación (2FA)	Alto, si combina factores independientes y resistentes al phishing	Añade una segunda barrera ante el robo de contraseñas	Puede generar dificultades de acceso si se pierde el segundo factor; algunos métodos pueden ser vulnerables al phishing
Biometría	Medio a alto, dependiendo del sistema y de la protección de las plantillas biométricas	Cómoda y vinculada a características físicas o conductuales	Puede presentar falsos rechazos, problemas de privacidad y dificultades para sustituir un identificador biométrico comprometido
Tokens de seguridad	Alto, especialmente con dispositivos criptográficos resistentes al phishing	Permiten verificar la identidad mediante un dispositivo o credencial segura	Pueden perderse, tener un costo adicional o requerir procedimientos de recuperación

Nota: El nivel de seguridad depende de la implementación. Un token criptográfico resistente al phishing no ofrece las mismas garantías que un código de un solo uso enviado por SMS.

¿Qué método sería más adecuado para una entidad financiera?

Para una entidad financiera se recomienda una estrategia de autenticación multifactor basada en riesgos, utilizando credenciales robustas y factores adicionales apropiados para cada operación.

Una alternativa especialmente recomendable es combinar una contraseña o mecanismo de acceso seguro con una llave de seguridad criptográfica resistente al phishing. Para operaciones sensibles, también pueden emplearse confirmaciones vinculadas a la transacción, controles de riesgo y notificaciones al cliente.

La biometría puede utilizarse como mecanismo complementario, siempre que se protejan adecuadamente los datos biométricos y se ofrezcan mecanismos alternativos de recuperación.

Conclusión: Ningún método es infalible por sí solo. La combinación de factores independientes, controles de acceso, monitoreo y recuperación segura proporciona una protección más sólida.

ACTIVIDAD 5. MATRIZ DE CONTROL DE ACCESO

Definición de permisos

- **L:** Lectura o consulta de información.
- **E:** Escritura o incorporación de nuevos datos.
- **M:** Modificación de información existente.

Los permisos se asignan según las funciones de cada usuario, siguiendo el principio de mínimo privilegio.

Matriz de permisos

Usuario	Sistema académico	Base de datos de notas	Plataforma virtual
Administrador	L, E, M	L, E, M	L, E, M
Docente	L, E, M*	L, E, M*	L, E, M
Estudiante	L	L**	L, E***

El docente puede modificar únicamente los datos y las notas correspondientes a sus cursos autorizados. No debe tener acceso general de administración a la base de datos.

El estudiante puede consultar únicamente sus propias notas, sin permisos para escribirlas o modificarlas.

El estudiante puede participar en actividades académicas autorizadas, como entregar tareas o publicar mensajes donde esté permitido, pero no modificar contenidos institucionales ni trabajos de otros usuarios.

Justificación

El administrador necesita permisos amplios para mantener los sistemas, gestionar usuarios y resolver problemas técnicos. Sin embargo, sus acciones deben quedar registradas y las cuentas privilegiadas deben contar con medidas de protección reforzadas.

El docente necesita consultar información académica, registrar calificaciones y gestionar los contenidos de sus cursos. Sus permisos deben limitarse a las asignaturas que tiene asignadas.

El estudiante requiere consultar sus datos y utilizar la plataforma educativa, pero no debe modificar calificaciones ni información de otros usuarios.

Conclusión: La matriz aplica el control de acceso basado en roles (RBAC), que facilita la administración de permisos y reduce el riesgo de accesos indebidos.

ACTIVIDAD 6. DEBATE SOBRE SEGURIDAD INFORMÁTICA

Tema: ¿Las organizaciones deben monitorear permanentemente las actividades digitales de sus trabajadores para garantizar la seguridad de la información?

Equipo A: A favor

Argumento principal: Las organizaciones deben implementar mecanismos de monitoreo de seguridad para detectar amenazas, prevenir fugas de información y responder oportunamente a incidentes.

Argumentos técnicos:

1. **Detección temprana:** Los registros de acceso pueden revelar intentos de intrusión, descargas inusuales o conexiones sospechosas.
2. **Protección de datos:** La supervisión ayuda a identificar posibles filtraciones de información confidencial.
3. **Respuesta a incidentes:** Los registros facilitan reconstruir los hechos, determinar el alcance del incidente y tomar medidas correctivas.
4. **Cumplimiento:** Los controles de auditoría pueden contribuir al cumplimiento de políticas internas y obligaciones legales.

Propuesta del equipo: Utilizar registros de autenticación, alertas automáticas y herramientas de detección de anomalías, limitando el acceso a los registros al personal autorizado.

Equipo B: En contra

Argumento principal: El monitoreo permanente e indiscriminado puede afectar la privacidad de los trabajadores, generar desconfianza y recopilar información personal que no resulta necesaria para proteger los sistemas.

Argumentos técnicos y éticos:

1. **Privacidad:** La supervisión excesiva puede invadir espacios personales y recopilar datos ajenos al trabajo.

2. **Riesgo de abuso:** Los registros podrían utilizarse para fines diferentes de los informados inicialmente.
3. **Costos:** La recopilación y revisión de grandes cantidades de datos requiere recursos técnicos y humanos.
4. **Falsos positivos:** Una actividad legítima puede interpretarse erróneamente como una amenaza.
5. **Protección de los registros:** Los datos de monitoreo también deben protegerse contra accesos no autorizados.

Propuesta del equipo: Aplicar monitoreo limitado a objetivos legítimos de seguridad, con información previa a los trabajadores, controles de acceso y periodos de conservación definidos.

Posición crítica y conclusión

La opción más equilibrada consiste en realizar un monitoreo proporcional, transparente y orientado a riesgos. No es necesario vigilar indiscriminadamente todas las actividades personales para proteger los sistemas.

Las organizaciones deben registrar los eventos relevantes para la seguridad, definir qué información recopilan, limitar quién puede consultarla y establecer plazos de conservación. Además, deben respetar la legislación laboral y de protección de datos aplicable.

De esta manera, se puede mejorar la seguridad informática sin ignorar los derechos y la privacidad de los trabajadores.

ACTIVIDAD 7. CASO INTEGRADOR

Informe técnico: incidente de seguridad en una empresa

1. Introducción

La empresa analizada sufrió un incidente de seguridad después de que un empleado compartiera su contraseña. Posteriormente, se produjo un acceso no autorizado y se alteraron registros financieros. Además, la organización no contaba con autenticación multifactor.

El incidente demuestra la importancia de establecer controles de autenticación, políticas de acceso, mecanismos de auditoría y procedimientos de respuesta. El análisis se centra en las amenazas materializadas, los objetivos de seguridad afectados y las medidas necesarias para prevenir nuevos incidentes.

2. ¿Qué amenazas se materializaron?

Se identifican las siguientes amenazas:

- **Compromiso de credenciales.** El empleado compartió su contraseña, lo que permitió que otra persona pudiera utilizarla. Esto representa una debilidad en la gestión de identidades y autenticación.
- **Acceso no autorizado.** Una persona utilizó o aprovechó las credenciales comprometidas para acceder a recursos de la empresa sin autorización legítima.

- **Alteración maliciosa de información.** Los registros financieros fueron modificados, lo que pudo afectar la exactitud de la información contable y las decisiones empresariales.
- **Ausencia de autenticación multifactor.** La falta de un segundo factor permitió que las credenciales comprometidas fueran una barrera insuficiente para proteger la cuenta.
- **Posibles deficiencias de supervisión.** La materialización del incidente indica que deben evaluarse los controles de registro, detección de anomalías y revisión de cambios. No obstante, no se puede afirmar que estos controles estuvieran completamente ausentes sin una investigación adicional.

3. ¿Qué objetivos de seguridad fueron afectados?

Objetivo	Afectación	Explicación
Confidencialidad	Comprometida potencialmente	El acceso no autorizado pudo permitir la consulta o divulgación de información financiera
Integridad	Comprometida directamente	Los registros financieros fueron alterados
Disponibilidad	No confirmada	No se informó que los sistemas dejaran de funcionar, aunque podría existir riesgo de interrupción durante la recuperación

La integridad es el objetivo afectado de forma más evidente. La confidencialidad también pudo verse comprometida, pero debe comprobarse qué información consultó o extrajo el atacante. La disponibilidad debe evaluarse para determinar si hubo pérdida de acceso o daños adicionales.

4. ¿Qué mecanismos de protección faltaban?

A partir de los hechos descritos, se recomienda implementar o reforzar los siguientes mecanismos:

- **Autenticación multifactor (MFA):** añade una barrera adicional al inicio de sesión y reduce la dependencia exclusiva de las contraseñas.
- **Control de acceso basado en roles (RBAC):** limita el acceso a la información según las funciones y responsabilidades del usuario.
- **Principio de mínimo privilegio:** concede únicamente los permisos necesarios para realizar cada tarea.
- **Registro y auditoría:** conserva evidencias de accesos, cambios en registros financieros y operaciones administrativas.
- **Alertas de actividad anómala:** detecta accesos desde ubicaciones inusuales, horarios atípicos o modificaciones masivas.

- **Copias de seguridad protegidas:** permiten recuperar información válida si las modificaciones maliciosas afectan los datos.
- **Gestión segura de contraseñas:** prohíbe compartir credenciales y establece procedimientos seguros para cambiarlas y recuperarlas.
- **Segregación de funciones:** evita que una sola persona pueda ejecutar todas las etapas críticas de una operación financiera sin supervisión.

Estos controles deben complementarse con capacitación de los empleados, actualizaciones de seguridad y procedimientos formales de respuesta ante incidentes.

5. ¿Qué política de seguridad propondría?

Se propone establecer una política de seguridad de la información con los siguientes componentes:

- **Gestión de identidades.** Cada trabajador tendrá una cuenta individual. Las credenciales serán confidenciales y no podrán compartirse. Se implementará MFA, especialmente en sistemas financieros, cuentas privilegiadas y accesos remotos.
- **Control de acceso.** Los permisos se asignarán de acuerdo con el cargo y las tareas autorizadas. Se revisarán periódicamente y se retirarán cuando cambien las funciones o termine la relación laboral.
- **Protección de registros financieros.** Las modificaciones importantes deberán quedar registradas con identificación del usuario, fecha, hora y detalle de la operación. Los cambios de alto riesgo podrán requerir aprobación adicional.
- **Respaldo y recuperación.** Se mantendrán copias de seguridad periódicas, protegidas contra modificaciones no autorizadas. La empresa probará regularmente la restauración de los registros.
- **Capacitación y cumplimiento.** Todos los empleados recibirán formación sobre contraseñas, phishing, manejo de datos y reporte de incidentes. Las infracciones se evaluarán conforme a la normativa interna y la legislación aplicable.
- **Respuesta ante incidentes.** La empresa deberá contar con un procedimiento para contener accesos sospechosos, revocar sesiones, cambiar credenciales comprometidas, preservar evidencias, verificar la integridad de los registros y recuperar información confiable.

Ante el incidente actual, la prioridad será bloquear los accesos comprometidos, asegurar las evidencias, identificar los cambios realizados y validar los registros financieros antes de restaurarlos o corregirlos.

6. ¿Qué modelo de control de acceso sería el más adecuado?

El modelo más adecuado como base es el control de acceso basado en roles (RBAC), complementado con el principio de mínimo privilegio y controles adicionales para operaciones financieras sensibles.

Mediante RBAC, los permisos se asignan según las funciones del trabajador. Por ejemplo, un empleado de contabilidad podría registrar operaciones autorizadas, mientras que la aprobación de ciertos movimientos corresponde a un supervisor distinto.

Este enfoque permite:

- Reducir los permisos innecesarios.
- Evitar que todos los trabajadores accedan a información financiera.
- Facilitar las auditorías y la revisión de privilegios.

- Aplicar la segregación de funciones.
- Simplificar la gestión de usuarios cuando cambian de puesto.

Para operaciones de riesgo elevado, se pueden añadir aprobaciones dobles, autenticación reforzada y controles basados en el contexto del acceso.

7. Conclusión

El incidente se produjo en un contexto de credenciales compartidas, acceso no autorizado y ausencia de autenticación multifactor. La alteración de los registros financieros demuestra que los controles de integridad deben ser una prioridad para la empresa.

La organización debe reforzar la autenticación, aplicar permisos basados en roles, mantener registros de auditoría y contar con copias de seguridad verificadas. También debe capacitar a sus trabajadores y disponer de un procedimiento claro de respuesta ante incidentes.

La seguridad de la información no depende de una única herramienta, sino de la combinación de tecnología, políticas, procedimientos y responsabilidad de los usuarios. La aplicación coordinada de estas medidas reducirá la probabilidad de incidentes similares y mejorará la capacidad de recuperación de la empresa.

CONCLUSIÓN GENERAL DEL TRABAJO

Las siete actividades permiten comprender que la seguridad informática requiere identificar amenazas, evaluar riesgos y aplicar mecanismos de prevención, detección y recuperación.

La confidencialidad protege la información frente a accesos no autorizados; la integridad garantiza que los datos sean correctos y no se alteren indebidamente; y la disponibilidad permite que los usuarios autorizados accedan a los recursos cuando los necesitan.

Para proteger adecuadamente una organización, se recomienda combinar autenticación multifactor, contraseñas robustas, control de acceso basado en roles, copias de seguridad, monitoreo proporcional, capacitación y políticas de seguridad claras. Estos elementos deben revisarse de forma periódica para responder a nuevas amenazas y mantener la protección de la información.